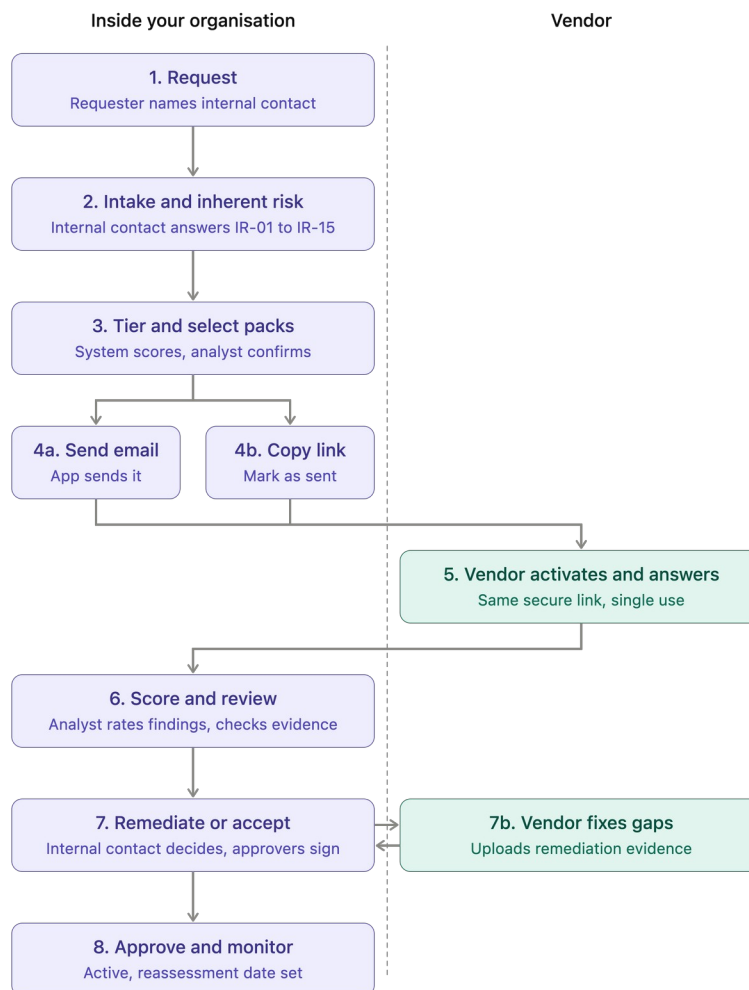


Third-party onboarding, step by step

How a vendor moves from a request to an approved, monitored relationship. Each block says who acts, what they do, what the system does on its own, what the vendor can and cannot see, and what has to be true before the flow moves on. Read down the internal lane; the flow crosses to the vendor lane only where an arrow says so.

Purple blocks: inside your organisation — profile, inherent risk, send, review, approval.

Green blocks: the vendor — sees the questionnaire and evidence requests only.



Internal: profile, inherent risk, send, review, approval Vendor: questionnaire and evidence only

The flow in detail

1. Request

Requester — any employee who needs the vendor

Enter

Vendor legal name, website, country, what the service is, business unit, estimated annual spend, target start date, and the internal contact who will own the relationship.

System

- Creates the record with an ID like VND-2026-0142.
- Checks for an existing vendor with the same name or domain and shows it before saving.
- Notifies the internal contact by email and in-app task: complete intake within 5 business days.

Moves on when the request is saved. **INTAKE**

▼ Internal contact receives the intake task

2. Intake and inherent risk

Internal contact — nothing in this step is shown to the vendor

Profile

Service description, customer data involved, hosting model, processing locations, critical subcontractors, contract renewal date, and the vendor's security contact (name and email) used in step 4.

Scope

Seven Yes / No / Unknown questions: sensitive data, software or API, cloud hosting, privileged or network access, critical operations, regulated service, physical delivery. These pick the question packs the vendor will get.

Inherent risk

IR-01 to IR-15, each rated Low / Moderate / High / Unknown with a one-line rationale. Unknown counts as High.

Finish

Tick the attestation and submit. Drafts save automatically.

System

Reminder on day 3 and day 5; escalates to the internal contact's manager on day 7; withdraws the request on day 14 if untouched.

Moves on when all 15 exposures are rated and the form is submitted. **TIER_REVIEW**

▼ Score and pack selection are computed instantly

3. Tier and select packs

System proposes, TPRM analyst confirms

System

- Averages the 15 scores (Low 1, Moderate 2, High or Unknown 3): under 1.5 Low, under 2.4 Moderate, otherwise High.
- Hard floor: a High on sensitive data (IR-02), privileged access (IR-04) or regulatory impact (IR-08) makes the tier Critical regardless of the average, and shows which answer caused it.
- Turns on Baseline (45 questions) plus every pack answered Yes in scope; packs answered Unknown are held as "Confirm scope".
- Sets the vendor's due date in business days by tier: Critical 10, High 15, Moderate 20, Low 25.

Analyst

- Accept the tier, or override it — an override needs a written reason.
- Resolve every "Confirm scope" pack to Yes or No after checking with the internal contact.
- Review the vendor security contact; correct it here if wrong.

Moves on when the tier is confirmed and no pack is left unresolved — Send stays disabled until then. READY_TO_SEND

▼ Analyst chooses how the invitation reaches the vendor

4a. Send email

Analyst clicks Send

App does

Emails the vendor security contact: your organisation's name, the vendor name, the due date, and the activation link. Copies the internal contact.

Tracks

Sent time and delivery status (queued / delivered / bounced). A bounce reopens the contact field for correction and resend.

4b. Copy link

Analyst sends it their own way

App does

Shows the same activation link and a short suggested message to paste into the analyst's own email, a procurement thread or the vendor's ticket system.

Analyst

Sends it, then clicks Mark as sent. Nothing starts until that click.

Rules for both send options

Apply whether the app sent the email or the analyst copied the link

- One link, tied to this vendor and this assessment. Single use: once activated, opening it again is rejected.
- Expires after 14 days. Regenerating a link invalidates the previous one.
- Packs are locked at send so the vendor never sees questions appear or vanish mid-way.
- The audit log records which option was used, by whom, and when. The SLA clock starts at send or at Mark as sent.
- Reminders go to the vendor on day 7 and day 12; the internal contact is told on the due date; the analyst and procurement on day 25.

Moves on when the email is sent or the link is marked as sent. `AWAITING_VENDOR`

 Invitation link goes to the vendor

5. Vendor activates and answers

Vendor security contact, in the vendor portal

Sees

Only the questions marked Answer — Baseline plus the packs selected in step 3 — with the control question, response guidance and expected evidence for each, grouped by domain. One evidence request per domain in scope.

Does

- Answers each question Yes / Partial / No / N/A and adds a comment (required for Partial, No and N/A).
- Uploads or links evidence against each domain; no passwords or secrets in uploads.
- Saves and resumes as often as needed, then submits. After submit the portal is read-only.

Never sees

Inherent risk answers, tier, question weights, scores, findings not marked for remediation, or any other vendor.

Portal

Own login, separate from your users. If the contact changes, the analyst updates it and regenerates the link.

Moves on when the vendor submits. `SUBMITTED`

 Responses return to the analyst

6. Score and review

TPRM analyst

System

- Scores each answered question: Yes 0, Partial 2 × weight, No 4 × weight; N/A scores 0 and is excluded from the maximum.
- Residual risk = score ÷ maximum: Low under 15%, Moderate under 35%, High under 60%, Critical 60% and above, shown overall and per domain.
- Creates a draft finding for every Partial or No, with severity from weight and answer.
- Marks each evidence request Received or Missing; flags audit reports older than 12 months.

Analyst

- Confirm, adjust (severity, with a note) or dismiss (with a reason) each draft finding.
- Mark evidence Accepted, Needs update or Rejected; a Needs update reopens that request for the vendor.
- Send a clarification request on any question; the vendor answers in the portal without reopening the whole questionnaire.
- Complete the review. SLA 5 business days (Critical and High: 10).

Moves on when the analyst completes the review. Straight to step 8 if there are no findings. FINDINGS_OPEN

▼ Each finding needs a decision

7. Remediate or accept

Internal contact decides, approvers sign

Per finding, choose one

- **Remediate** — the vendor must fix it. Due date by severity: High 30 days, Moderate 90, Low 180. Critical must be fixed before approval.
- **Accept risk** — write the business justification. It is routed for approval and expires after at most 12 months.

Approvals

Low: internal contact's manager (3 days). Moderate: business unit leader, then TPRM lead (5 days). High or Critical: business unit leader, then CISO (10 days). Rejected acceptances go back to Remediate.

System

Tracks every due date, reminds owners, and records each acceptance in the risk register with its expiry.

Moves on when every finding is Closed, Accepted, or scheduled for remediation after approval with an agreed date. APPROVAL

 Findings marked Remediate go to the vendor

7b. Vendor fixes gaps

Vendor security contact, in the same portal

Sees

Only findings marked Remediate, each with the gap, the expected control and the due date. Accepted findings and internal notes are not shown.

Does

Uploads remediation evidence or a dated plan and marks the item Ready for review.

Then

The analyst validates and closes the finding, or sends it back with what is still missing. Repeats until every remediation item is closed.

 All findings resolved

8. Approve and monitor

System, on the final approval

System

- Sends the approval notice to the requester, internal contact, procurement and legal: tier, residual risk, accepted risks, open remediation dates.
- Sets the reassessment date by tier: Critical and High 12 months, Moderate 24, Low 36. Reminds 30 days before.
- Tracks the contract renewal date and warns 90 days before.
- Watches for expiring evidence (SOC 2, ISO) and expiring risk acceptances, and creates a task 30 days ahead.

Internal contact

Keeps owning the vendor: report a change of scope (new data, new integration, new location — this re-runs step 2), respond to reassessment requests, report incidents, and start offboarding when the relationship ends.

Moves on when done. Monitoring and reassessment take over. **ACTIVE**

Quick reference

Step	Who	Key rule	Status after
1 Request	Requester	Duplicate check; intake task, 5 business days	INTAKE
2 Intake	Internal contact	Profile + 7 scope + IR-01-15; Unknown = High	TIER_REVIEW
3 Tier	System, analyst	Avg <1.5 Low, <2.4 Moderate, else High; hard floor → Critical	READY_TO_SEND
4a / 4b Send	Analyst	One single-use 14-day link; Mark as sent on copy	AWAITING_VENDOR
5 Vendor answers	Vendor contact	Baseline + selected packs; Yes/Partial/No/N/A + evidence	SUBMITTED
6 Review	Analyst	Yes 0, Partial 2×w, No 4×w; <15 / <35 / <60 / ≥60	FINDINGS_OPEN
7 Decide	Internal contact, approvers	Remediate 30/90/180 days or accept ≤12 months	APPROVAL
8 Approve	System	Reassess 12 / 24 / 36 months; renewal warning 90 days	ACTIVE